

User ID Controlled by Request Parameter, with Unpredictable User IDs

Lab Information

Field	Value
Category	Access Control
Difficulty	Apprentice
Vulnerability	Insecure Direct Object Reference (IDOR)
Impact	Horizontal Privilege Escalation

Summary

This lab demonstrates an **IDOR vulnerability** where the application uses unpredictable user identifiers (GUIDs) but fails to perform proper authorization checks.

Although the user IDs are difficult to guess, the identifiers are exposed through publicly accessible content. An attacker can obtain another user's identifier and use it to access private account information, including sensitive data such as API keys.

Objective

Find the GUID associated with the user **carlos** and retrieve his API key.

Attack Scenario

The application identifies users using unique GUID values instead of predictable usernames.

However, using unpredictable identifiers does not prevent unauthorized access if the server does not verify whether the authenticated user owns the requested resource.

An attacker can discover another user's GUID from publicly available information and use it in a request to access that user's account data.

Steps to Reproduce

1. Log in using the provided credentials:

```
```text id="6t1h1w" Username: wiener Password: peter
```

2. Navigate through the application and inspect publicly accessible content such as blog posts.

3. Identify a blog post created by the user **\*\*carlos\*\***.

4. Observe the user identifier in the URL or request:

```
```text id="qxy5fz"
userId=0a3c6646-1ad4-41fa-ac01-a63770e25099
```

1. Copy Carlos's GUID.

2. Navigate to the account endpoint and replace your own user identifier with Carlos's identifier.

Example:

Before:

```
```text id="4q7n8z" userId=<your-user-id>
```

After :

```
```text id="85fkmx"
userId=0a3c6646-1ad4-41fa-ac01-a63770e25099
```

1. Send the request.
2. Observe Carlos's account information and extract the API key.
3. Submit the API key to solve the lab.

Evidence

Discovered GUID

The user's GUID was obtained from publicly accessible content:

```
text id="2m7h4k"
userId=0a3c6646-1ad4-41fa-ac01-a63770e25099
```

Modified Request

The user identifier was replaced with Carlos's GUID.

Result

The application returned Carlos's account information, including his API key.

Security Impact

An attacker can access private information belonging to other users without authorization. Sensitive data such as API keys, personal information, or account details may be exposed.

In real-world applications, similar vulnerabilities can lead to unauthorized access to customer data, account takeover scenarios, or privacy violations.

Root Cause

The application relied on unpredictable identifiers as a security measure but failed to implement proper authorization checks.

The server verified that the identifier existed but did not verify whether the authenticated user was allowed to access that specific resource.

Remediation

- Implement server-side authorization checks for every resource request.
 - Verify ownership before returning sensitive user data.
 - Do not rely on GUIDs, UUIDs, or random identifiers as a replacement for authorization.
 - Limit exposure of sensitive object identifiers where possible.
-

Pentester's Notes

This lab demonstrates an important security principle:

"Unpredictable identifiers are not a replacement for access control."

During testing, even if IDs are UUIDs or GUIDs, they should still be considered potential IDOR targets.

Useful places to look for exposed identifiers include:

- Blog posts
 - Public profiles
 - Comments
 - API responses
 - JavaScript files
 - Metadata
-

Key Takeaways

- Random IDs reduce guessing attacks but do not fix authorization flaws.
- IDOR vulnerabilities depend on missing authorization checks, not predictable IDs.
- Always test whether changing object references exposes another user's data.
- Publicly available information can reveal identifiers that appear hidden.